1. Introduction

1.1 Purpose of the Project

The purpose of this project is to design, implement, and validate a detection mechanism in Elastic SIEM for identifying brute-force authentication attacks within a controlled lab environment.

Brute-force attacks are commonly used by adversaries to gain unauthorized access to systems by repeatedly attempting different password combinations until valid credentials are discovered. These attacks often target remote access services such as SSH, RDP, or web login portals.

Detecting brute-force behavior is critical because it represents a potential initial access attempt in the attack lifecycle.

This project demonstrates:

• Detection engineering using Elastic Security
• Authentication log monitoring
• Behavioral detection rule creation
• Alert investigation workflow in a SOC environment
• MITRE ATT&CK mapping for credential attacks

The goal is to simulate a brute-force attack on an attacker machine and build a reliable detection rule that identifies abnormal authentication behavior.

1.2 Overview of Brute-Force Attacks

A brute-force attack is a password-guessing technique where an attacker attempts many authentication requests using different password combinations.

Attackers typically use automated tools and password lists to test large numbers of credential combinations quickly.

Common characteristics of brute-force attacks include:

• Multiple failed login attempts
• Rapid authentication requests
• Repeated attempts targeting the same user account
• Attempts originating from a single source IP address

If successful, a brute-force attack may lead to:

• Unauthorized system access
• Privilege escalation
• Data exfiltration
• Lateral movement inside the network

Because brute-force attempts generate multiple authentication failures, they leave a clear pattern in authentication logs that can be used for detection.

1.3 Importance of Authentication Attack Detection

Authentication attacks represent one of the most common methods used by adversaries to gain access to systems.

From a SOC perspective, monitoring authentication failures helps detect malicious activity such as:

• Credential guessing attacks
• Password spraying
• Account takeover attempts
• Automated login attacks

Early detection of brute-force attempts allows defenders to:

• Block attacker IP addresses
• Lock compromised accounts
• Enforce stronger authentication controls
• Prevent unauthorized access to sensitive systems

Therefore, monitoring and detecting abnormal authentication patterns is an essential capability for modern security operations centers.

1.4 Tools and Technologies Used

The project environment uses the following components:

Attacker Machine
• Kali Linux
• Hydra password attack tool

Target System / SIEM Host
• Windows 11
• Sysmon for advanced logging

SIEM Platform
• Elastic Stack (Elasticsearch + Kibana)

Log Forwarding
• Winlogbeat

Logging Sources
• Windows Security Event Logs
• Sysmon telemetry

The detection rule will analyze authentication failure events and identify suspicious login behavior indicative of brute-force attacks.

2. Lab Architecture and Environment Setup

2.1 Lab Overview

This project was conducted in a controlled virtual lab environment designed to simulate a real-world Security Operations Center (SOC) monitoring scenario.

The lab environment consists of two primary systems:

1. Kali Linux (Attacker Machine)
2. Windows 11 (Target System and SIEM Host)

In this setup, the Windows 11 system serves two purposes:

• Target system for the brute-force authentication attack
• Centralized SIEM platform hosting the Elastic Stack

Although production environments typically separate SIEM infrastructure from monitored endpoints, combining these roles in a single system is acceptable for lab-based detection engineering exercises.

The purpose of this architecture is to:

• Generate authentication attack traffic from the attacker system
• Capture authentication logs on the Windows 11 machine
• Forward logs to Elastic SIEM using Winlogbeat
• Create detection rules to identify brute-force login attempts

2.2 Network Topology

The network topology follows an attacker-to-target monitoring model, where the SIEM is hosted on the target machine.

```
Kali Linux (Attacker)
      │
      │  Brute Force Login Attempts
      ▼
Windows 11 (Target + Elastic SIEM Host)
      │
      │  Winlogbeat → Elasticsearch
      ▼
Elastic Security (Kibana)
```

Traffic Flow Explanation

1. The Kali Linux machine initiates multiple authentication attempts targeting the Windows 11 system.
2. Windows 11 records authentication failures in the Windows Security Event Logs.
3. Sysmon and Windows Security logs capture authentication-related telemetry.
4. Winlogbeat collects and forwards these logs to Elasticsearch.

5. Elastic Security analyzes the logs and triggers alerts when brute-force behavior is detected.

2.3 System Specifications

Attacker Machine

Operating System
• Kali Linux

Primary Tool
• Hydra (Password attack tool)

Role
• Generate brute-force login attempts against the target system.

Target System and SIEM Host

Operating System
• Windows 11

Roles
• Target of authentication attack
• Host system for Elastic Stack

Logging Sources
• Windows Security Event Logs
• Sysmon Telemetry

Log Forwarder
• Winlogbeat

2.4 IP Addressing Scheme

Documenting IP addresses is important because detection queries will rely on network-related fields such as source.ip and destination.ip.

Example IP configuration:

• Kali Linux IP: 192.168.76.101
• Windows 11 IP: 192.168.76.100
• Network Mode: NAT / Host-Only / Bridged

2.5 Logging Verification

Before executing the brute-force attack simulation, it is necessary to confirm that authentication logs are being successfully collected and forwarded to Elastic.

Verification steps:

1. Confirm that the Winlogbeat service is running on the Windows system.
2. Generate a test login failure on the Windows machine.

3. Open Kibana → Discover.
4. Apply the filter:
    - event.code: 4625

Event ID 4625 represents a failed login attempt in Windows Security logs.

Confirm that the following fields are present in the logs:

• source.ip
• user.name
• event.code
• host.name
• @timestamp

These fields will later be used to create the brute-force detection rule.

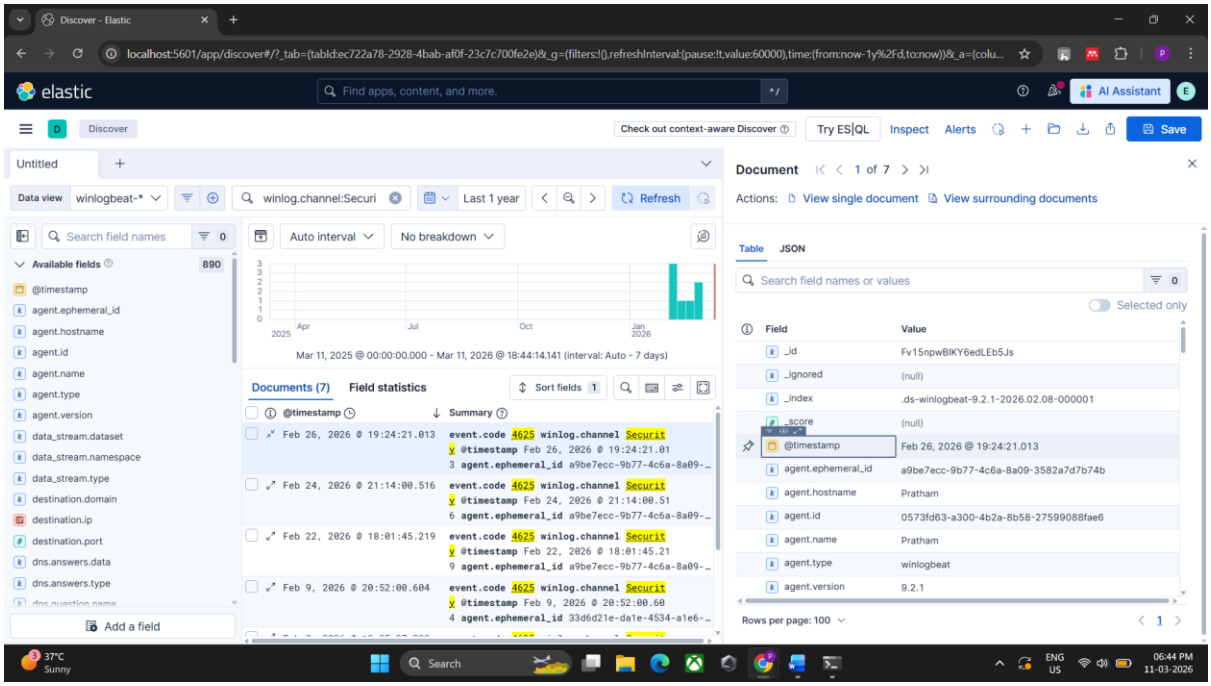

Figure 1 – kiabana windows logs

3. Windows Logging Configuration

3.1 Required Log Source

For brute-force authentication detection, the primary log source used in this project is the Windows Security Event Log.

The specific event used for detection is:

Event ID: 4625

Event ID 4625 is generated whenever a login attempt fails on a Windows system.

This event is extremely valuable for security monitoring because it records detailed information about authentication failures, including the source of the login attempt and the targeted user account.

Brute-force attacks generate a large number of authentication failures in a short time period. By monitoring Event ID 4625, it is possible to identify abnormal authentication patterns that indicate credential guessing or password attacks.

Key information contained in Event ID 4625 includes:

• Source IP address of the login attempt
• Target username
• Logon type
• Host machine generating the log
• Timestamp of the authentication attempt

Monitoring these fields enables detection of repeated login failures originating from a single source.

3.2 Enable Required Audit Policy

To ensure authentication failures are logged properly, the Windows Audit Policy must be configured to record logon events.

The required audit policy is:

Audit Logon – Failure

This setting ensures that all failed authentication attempts are recorded in the Windows Security log.

To verify the audit policy configuration, run the following command in an elevated Command Prompt:

- auditpol /get /subcategory:"Logon"

The expected result should show:

- Failure = Enabled

If this setting is not enabled, authentication failure events such as Event ID 4625 will not be recorded.

If necessary, the setting can be enabled through:

- Local Security Policy →
- Security Settings →
- Advanced Audit Policy Configuration →
- Logon/Logoff →
- Audit Logon → Enable Failure

This configuration ensures that failed login attempts are captured for security monitoring.

3.3 Winlogbeat Configuration

Winlogbeat is responsible for collecting Windows event logs and forwarding them to Elasticsearch for analysis.

For authentication monitoring, Winlogbeat must be configured to collect Security logs, where Event ID 4625 is stored.

The configuration file winlogbeat.yml should contain the following section:

```
winlogbeat.event_logs:
  - name: Security
```

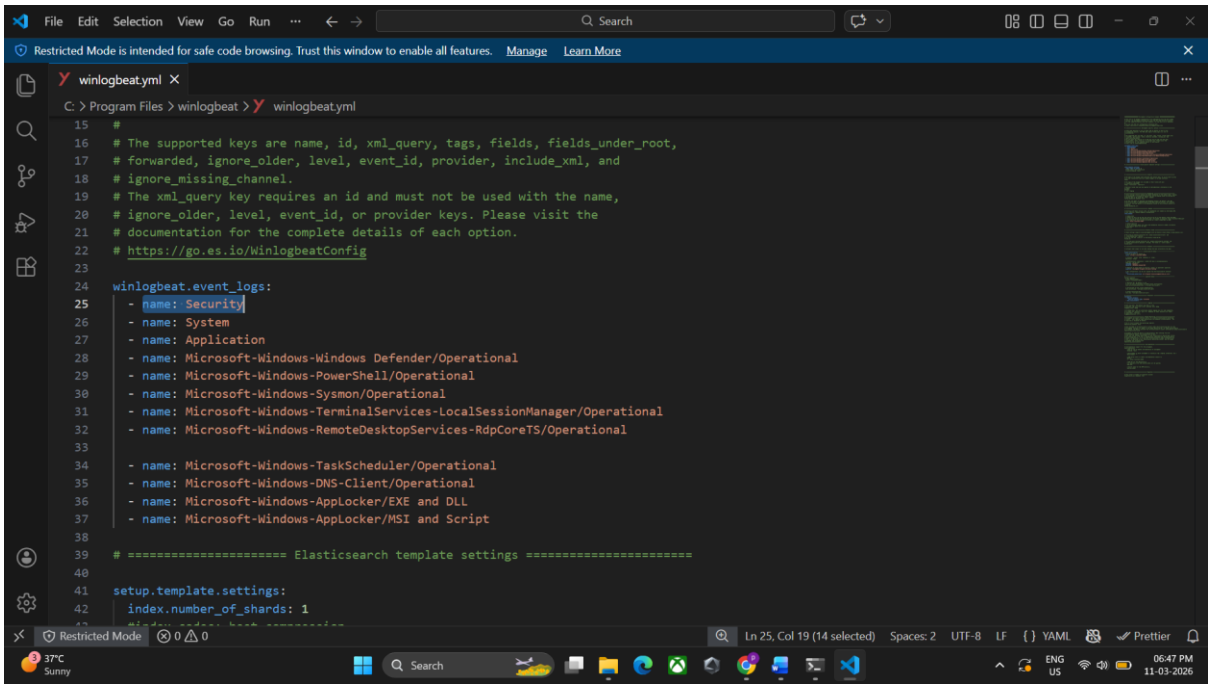

Figure 2 – Add security logs field in winlogbeat.yml

This configuration allows Winlogbeat to collect authentication-related events including:

- Successful logins
- Failed login attempts
- Account lockouts
- Authentication errors

After confirming the configuration:

1. Restart the Winlogbeat service.
2. Verify the service status.
3. Confirm that logs are being forwarded to Elastic.

Winlogbeat ensures near real-time ingestion of authentication logs into the Elastic SIEM.

3.4 Log Verification in Elastic

After configuring logging and Winlogbeat, it is necessary to confirm that authentication failure logs are visible in Elastic.

Open:

- Kibana → Discover

Apply the following filter:

- winlog.channel:Security AND event.code:4625

If authentication failures have occurred on the system, the corresponding logs should appear in the Discover view.

When inspecting the logs, confirm the presence of the following fields:

• source.ip – IP address that initiated the login attempt
• user.name – Target username of the login attempt
• event.code – Authentication event ID
• host.name – System generating the log
• @timestamp – Time of the event

These fields will be used later for detection rule creation and investigation analysis.

If the logs appear correctly in Discover, the logging configuration is verified and the environment is ready for attack simulation.

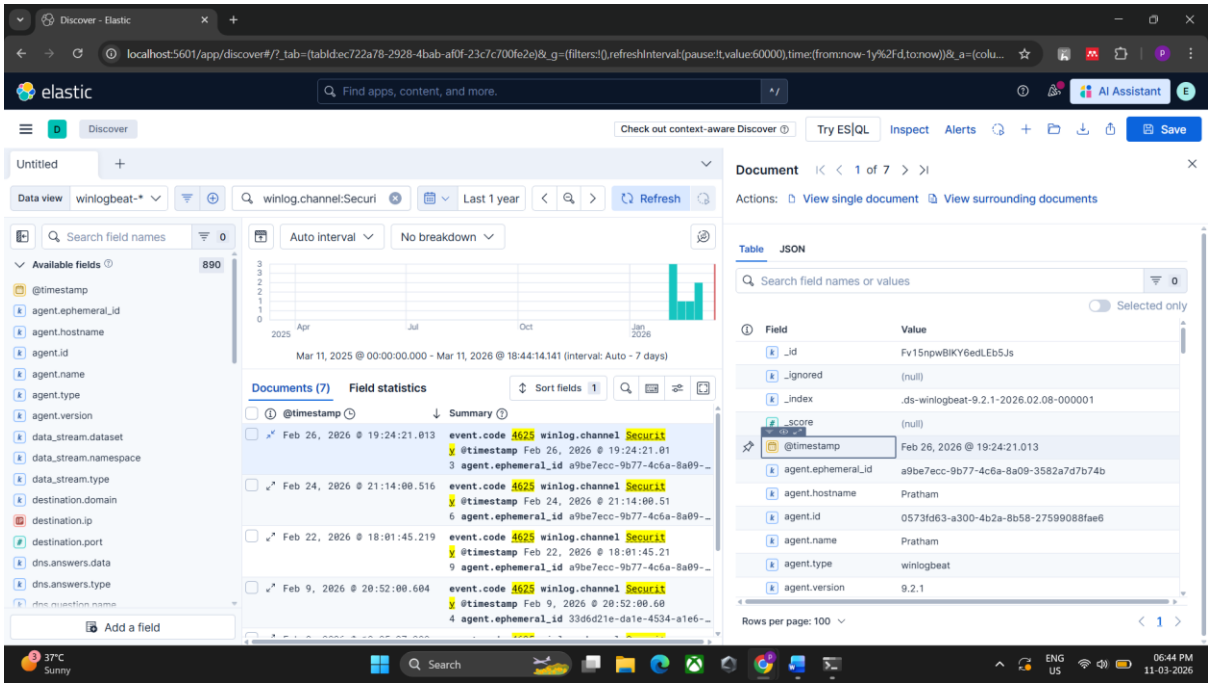

Figure 3 – Windows security logs with event code 4625

4. Attack Simulation – Authentication Brute-Force Attack

4.1 Objective

The objective of this phase is to simulate a brute-force authentication attack from the Kali Linux attacker machine targeting the Windows 11 system.

The attack will generate multiple authentication attempts using incorrect credentials in order to trigger Windows Security Event ID 4625 logs. These logs represent failed login attempts and are collected by Winlogbeat and forwarded to the Elastic SIEM platform.

The generated logs will later be analyzed to identify behavioral patterns associated with brute-force authentication attacks. These patterns will then be used to develop and validate a custom detection rule within Elastic Security.

4.2 Attacker and Target Information

Before launching the attack simulation, confirm the IP addresses of both systems in the lab environment.

Example configuration:

Attacker Machine
• Operating System: Kali Linux
• Role: Attack simulation system
• IP Address: 192.168.76.101

Target System
• Operating System: Windows 11
• Role: Target system and Elastic SIEM host
• IP Address: 192.168.76.100

Documenting these IP addresses is important because they will be used later during log analysis and investigation.

4.3 Network Connectivity Verification

Before performing the brute-force attack, verify that the Kali Linux system can communicate with the Windows target machine.

From the Kali Linux machine, run the following command:

- ping <Windows_IP>

Example:

- ping 192.168.76.100

A successful ping response confirms that the attacker machine can reach the target system over the network.

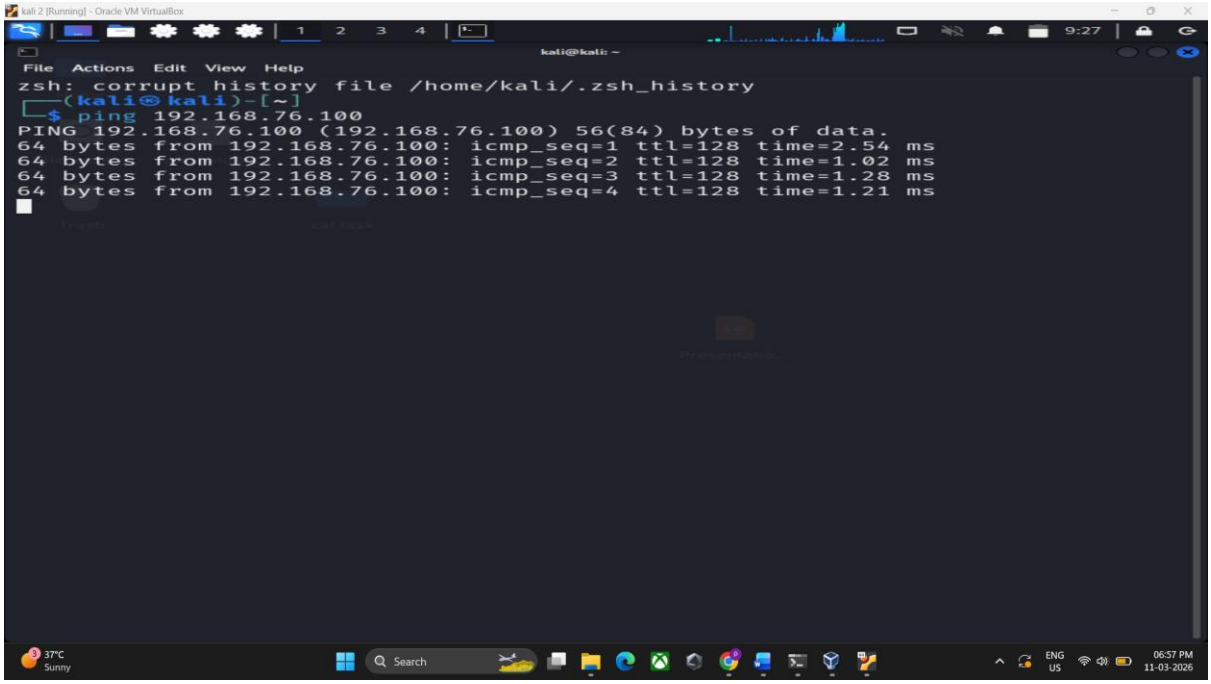

Figure 4 – Successful ping response from Kali Linux to Windows 11

4.4 Username Enumeration Using SMB

Before performing a brute-force password attack, attackers typically attempt to discover valid usernames on the target system. One of the most common methods is SMB user enumeration.

Attackers can enumerate user accounts over SMB using the enum4linux tool.

From the Kali Linux machine, run:

enum4linux 192.168.76.100

The tool queries the target system using SMB and RPC protocols to gather information such as:

- User accounts
- Domain information
- Shared resources
- Security identifiers

Identifying valid usernames significantly increases the success rate of brute-force attacks because the attacker can focus on password guessing instead of guessing both usernames and passwords.

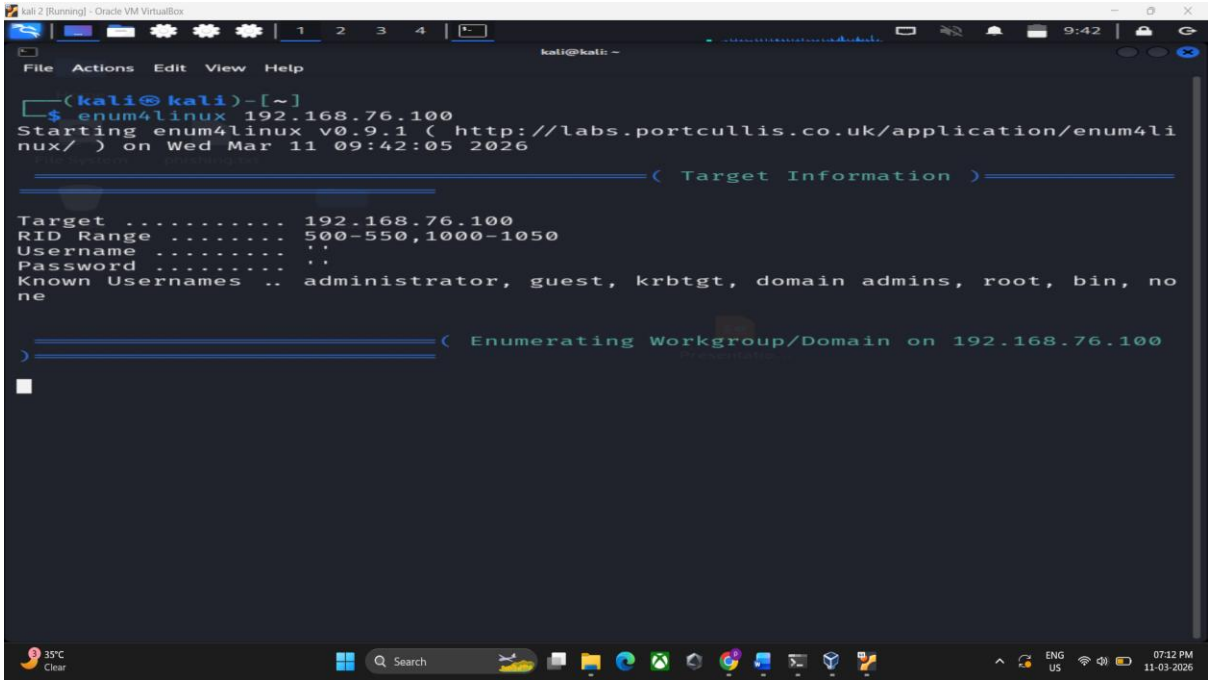

Figure 5 – SMB user enumeration using enum4linux

4.5 Creating a Custom Password Wordlist

Instead of using very large password lists such as rockyou.txt, attackers may create a small custom password list targeting a specific user. This allows faster testing and easier log generation for lab environments.

From the Kali Linux machine, create a password list:

- nano passwords.txt

Add the following example passwords:

- 123456
- password
- admin
- admin123
- pratham123
- test123
- welcome1

Save and exit the file.

This custom wordlist will be used by the Hydra tool to attempt authentication against the target system.

4.6 Brute-Force Attack Execution (SMB Authentication Simulation)

After identifying a valid username and preparing the password list, the attacker launches a brute-force authentication simulation targeting the SMB service on the Windows system.

Initially, the Hydra password-cracking tool was used to perform a dictionary-based attack. Hydra is a commonly used password-guessing tool capable of testing credentials against various network protocols such as SSH, FTP, HTTP, and SMB.

From the Kali Linux machine, the following command was executed:

hydra -l Pratham -P passwords.txt smb://192.168.76.100

Command Explanation

Parameter	Description
hydra	Password attack tool
-l Pratham	Target username
-P passwords.txt	Custom password wordlist
smb://	Target authentication protocol
192.168.76.100	Windows target system

Hydra attempts authentication against the SMB service using multiple passwords from the provided wordlist.

However, during testing it was observed that Hydra encountered compatibility issues with modern SMB implementations (SMBv3 with signing enabled), which resulted in errors such as:

- [ERROR] invalid reply from target smb://192.168.76.100:445/

Because of this limitation, the authentication simulation was performed using direct SMB authentication attempts from the Kali Linux machine.

A manual SMB authentication attempt was executed using:

- smbclient -L //192.168.76.100 -U Pratham

When an incorrect password was entered, the system returned the following response:

- NT_STATUS_LOGON_FAILURE

Each failed authentication attempt generated a Windows Security log event.

These failed login attempts are recorded in the Windows Security logs as:

- Event ID: 4625 – An account failed to log on

By repeating authentication attempts using incorrect passwords from the attacker machine, multiple failed login events were generated within a short time period.

This behavior successfully simulates a credential brute-force attack scenario, where an attacker repeatedly attempts to authenticate using different passwords.

Troubleshooting

During the brute-force attack simulation, several common issues may occur due to tool compatibility, firewall settings, or password wordlist configuration. The following troubleshooting steps were used during the lab.

1. RockYou Wordlist Not Found Error

While running Hydra, the following error may appear:

- [ERROR] File for passwords not found:
- /usr/share/wordlists/rockyou.txt

This happens because the rockyou password list is compressed by default in Kali Linux.

Verify the Wordlist Directory

Run the following command:

- ls /usr/share/wordlists

The output may show:

- rockyou.txt.gz

The .gz extension indicates the file is compressed.

Extract the Wordlist

Run:

- sudo gzip -d /usr/share/wordlists/rockyou.txt.gz

Verify extraction:

- ls /usr/share/wordlists

Now the output should display:

- rockyou.txt

The wordlist can now be used by password testing tools.

2. Hydra SMB Authentication Error

During testing, Hydra may produce the following error:

- [ERROR] invalid reply from target smb://192.168.76.100:445/

This occurs because modern Windows systems use SMBv3 with SMB signing enabled, while Hydra's SMB module was designed for older SMB implementations.

Because of this protocol mismatch, Hydra may fail to correctly process authentication responses.

Resolution

To confirm authentication attempts were still possible, manual SMB authentication was tested using:

- smbclient -L //192.168.76.100 -U Pratham

Entering an incorrect password produced:

- NT_STATUS_LOGON_FAILURE

This confirms that authentication attempts are reaching the Windows system and generating failed login events.

3. SMB Connection Timeout Error

Another issue observed during testing was the following message when using tools such as CrackMapExec:

NETBIOS connection with the remote host timed out

This can occur due to:

- Windows Firewall restrictions
- SMB session rate limiting
- SMB signing enforcement
- Temporary connection blocking after repeated authentication attempts

Verification Step

To verify that the SMB service was reachable, a port scan was performed from the Kali Linux machine:

- nmap -p 445 192.168.76.100

Expected result:

- 445/tcp open microsoft-ds

If the port appears as filtered, SMB access may be blocked by the firewall.

4. Confirm SMB Authentication Connectivity

To verify authentication connectivity between Kali Linux and the Windows system, the following command was executed:

- smbclient -L //192.168.76.100 -U Pratham

If the response shows:

- NT_STATUS_LOGON_FAILURE

this indicates that the authentication request successfully reached the Windows system.

Each failed authentication attempt generates a Windows Security Event ID 4625 log entry.

4.7 Expected System Behavior

During the brute-force authentication simulation, the Windows system records authentication failures for each incorrect login attempt.

Each failed login generates a Windows Security Event ID 4625 entry.

These events contain important information including:

- source.ip – IP address of the attacker
- user.name – Username used for authentication
- event.code – Authentication event identifier
- host.name – Target system hostname
- @timestamp – Time of authentication attempt

Because multiple authentication attempts are generated within a short time window, the logs appear as a cluster of failed login events originating from the same IP address.

This pattern is a key indicator used to detect brute-force authentication attacks in a Security Operations Center (SOC).

4.8 Log Verification in Elastic

After executing the authentication attack simulation, it is necessary to verify that the generated authentication failure logs are successfully collected and indexed within the Elastic SIEM platform.

This step confirms that the logging pipeline consisting of Windows Security Logs → Winlogbeat → Elasticsearch → Kibana is functioning correctly.

Viewing Logs in Kibana

Open the Elastic interface and navigate to:

- Kibana → Discover

In the search bar, run the following query:

- winlog.channel:Security AND event.code:4625

This query filters all authentication failure events recorded in the Windows Security log.

Event ID 4625 represents failed login attempts.

Filtering Attack Activity

To isolate the brute-force authentication attempts generated during the lab, filter the results using the attacker machine's IP address.

Run the following query:

- winlog.channel:Security AND event.code:4625 AND source.ip:192.168.76.101

This query displays authentication failures originating from the Kali Linux attacker system.

Observing the Attack Pattern

The results should display multiple authentication failure events occurring within a short time period.

Typical fields observed include:

Field	Description
source.ip	IP address of the attacker machine
user.name	Target username used during login attempt
event.code	Authentication event identifier (4625)
host.name	Target system hostname
@timestamp	Time of authentication attempt

Because the attacker performs repeated authentication attempts, the logs appear as a cluster of failed login events from the same IP address within a short time window.

This pattern is a key behavioral indicator used to detect brute-force attacks in Security Operations Centers.

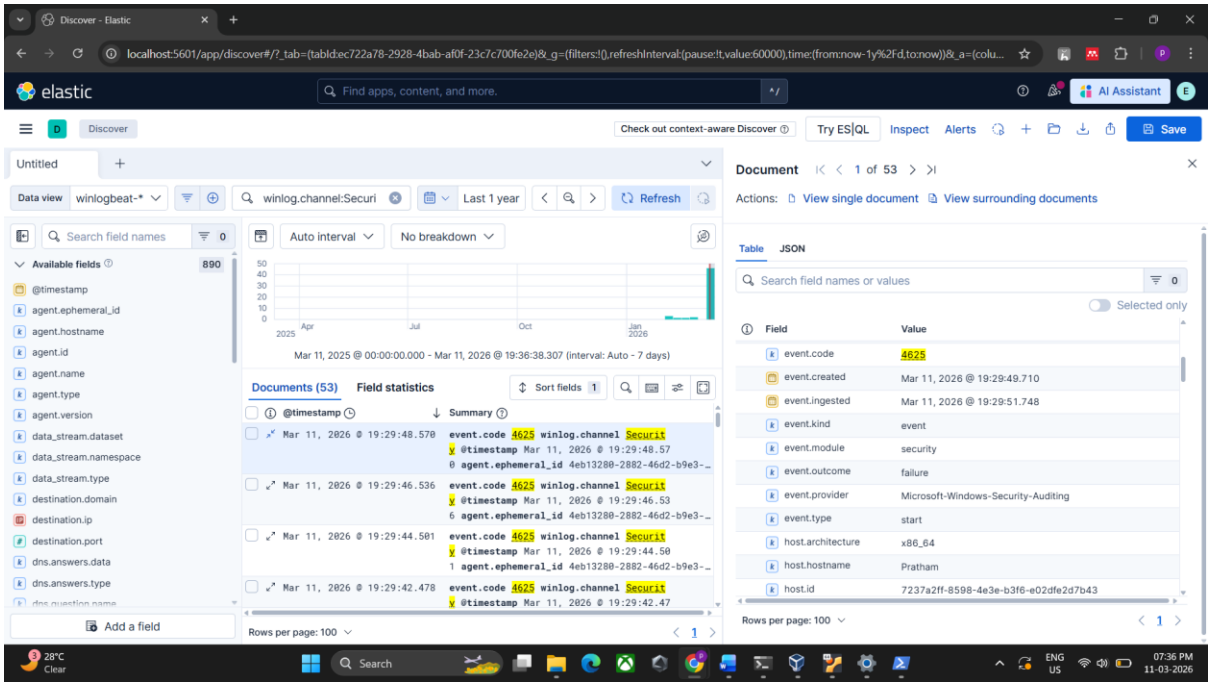

Figure 6 – Elastic Discover displaying multiple Event ID 4625 authentication failures

The screenshot should clearly show the following fields:

- source.ip
- user.name

- event.code
- host.name
- @timestamp

This evidence confirms that the brute-force simulation successfully generated security logs that can be analyzed in the next phase of the project.

5. Detection Rule Creation – Brute Force Authentication Detection

5.1 Objective

The objective of this phase is to develop a detection rule in Elastic Security capable of identifying brute-force authentication attacks.

During the previous phase, multiple failed authentication events were generated using incorrect credentials. These failed login attempts produced Windows Security Event ID 4625 logs, which were successfully collected and stored in the Elastic SIEM platform.

The goal of this section is to analyze those logs and create a detection rule that automatically identifies abnormal authentication patterns such as repeated login failures originating from the same source IP address.

This type of detection is commonly implemented in Security Operations Centers to identify credential brute-force attacks and password guessing activity.

5.2 Identifying the Detection Pattern

Before creating the detection rule, it is important to analyze the behavior generated during the attack simulation.

During the brute-force attack simulation, the following pattern was observed:

- Multiple authentication failures occurred within a short time period
- The login attempts originated from the same source IP address
- The same user account was repeatedly targeted

5.3 Creating the Detection Rule in Elastic

To detect this behavior automatically, a detection rule can be created within Elastic Security.

Navigate to:

- Kibana → Security → Rules

Click:

- Create Rule

Select the rule type:

- Custom Query Rule

5.4 Detection Query

The detection rule will monitor Windows authentication failure events using the following query:

- winlog.channel:Security AND event.code:4625

This query identifies failed authentication attempts recorded in the Windows Security log.

5.5 Rule Configuration

Configure the rule with the following parameters:

Setting	Value
Rule Name	Windows Brute Force Authentication Detection
Severity	Medium
Risk Score	50
Rule Type	Custom Query
Index Pattern	winlogbeat-*

MITRE ATT&CK Mapping

The detection rule is mapped to the MITRE ATT&CK framework to align the detection with known adversary techniques.

MITRE Field	Value
Tactic	Credential Access
Technique	Brute Force
Technique ID	T1110
Sub-Technique	Password Guessing
Sub-Technique ID	T1110.001

Description:

The Brute Force (T1110) technique describes scenarios where attackers repeatedly attempt authentication using multiple password guesses until the correct credentials are discovered.

In this lab simulation, the attacker repeatedly attempted authentication against the Windows SMB service using incorrect credentials, generating multiple failed login attempts recorded as Event ID 4625.

5.6 Threshold Configuration

To detect brute-force activity, configure a threshold condition.

Example threshold:

- More than 5 failed logins
- From the same source IP
- Within 1 minute

Threshold configuration:

Field	Value
Group By	source.ip
Threshold	5
Time Window	1 minute

This configuration will trigger an alert when more than five failed authentication attempts occur from the same IP address within one minute.

5.7 Expected Alert Behavior

When the detection rule is active, the Elastic SIEM will automatically generate an alert whenever brute-force behavior is detected.

The alert will contain information such as:

- Attacker IP address
- Target username
- Host machine
- Number of failed attempts
- Time of detection

Example alert data:

Field	Example Value
source.ip	192.168.76.101
user.name	Pratham
event.code	4625
host.name	pratham
attempts	8

5.8 Alert Investigation

When the alert is triggered, analysts can investigate the activity by reviewing related authentication logs in Elastic.

The investigation process typically involves:

- Reviewing failed login attempts
- Identifying the attacker source IP
- Determining the targeted user accounts
- Checking for successful logins following repeated failures

This process helps determine whether the activity represents a malicious brute-force attack or normal user behavior.

Capture the rule configuration screen showing:

- Rule name
- Query
- Threshold configuration

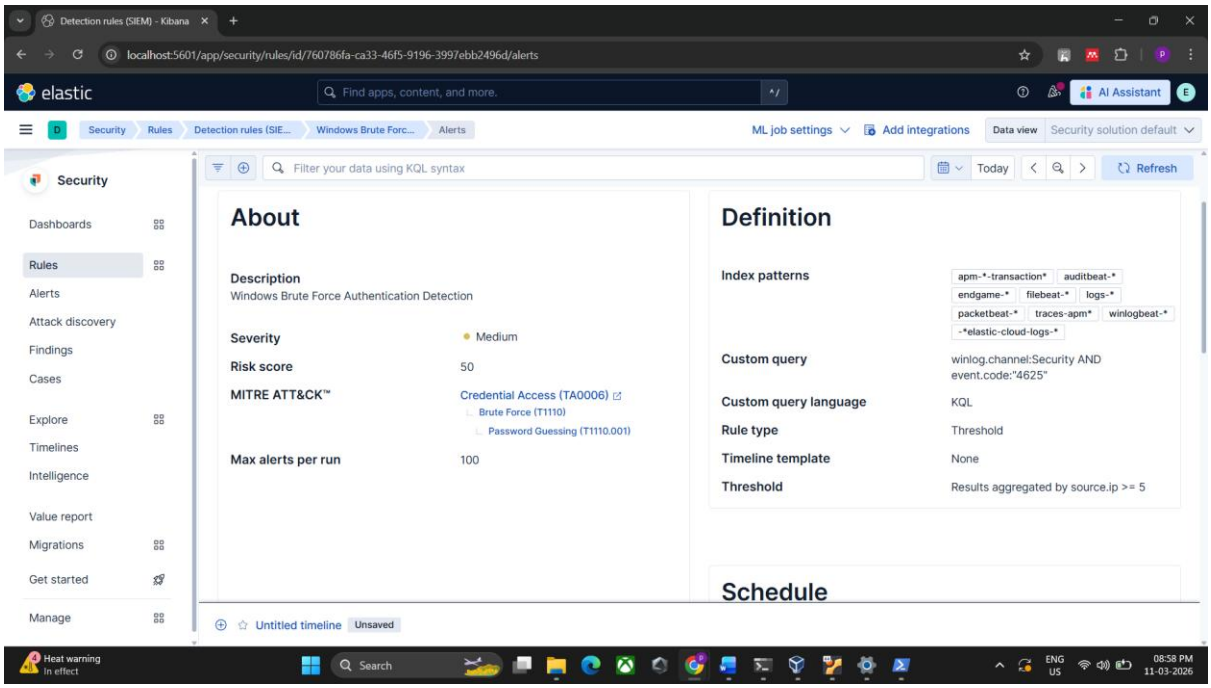

Figure 7 – Elastic SIEM brute-force detection rule configuration

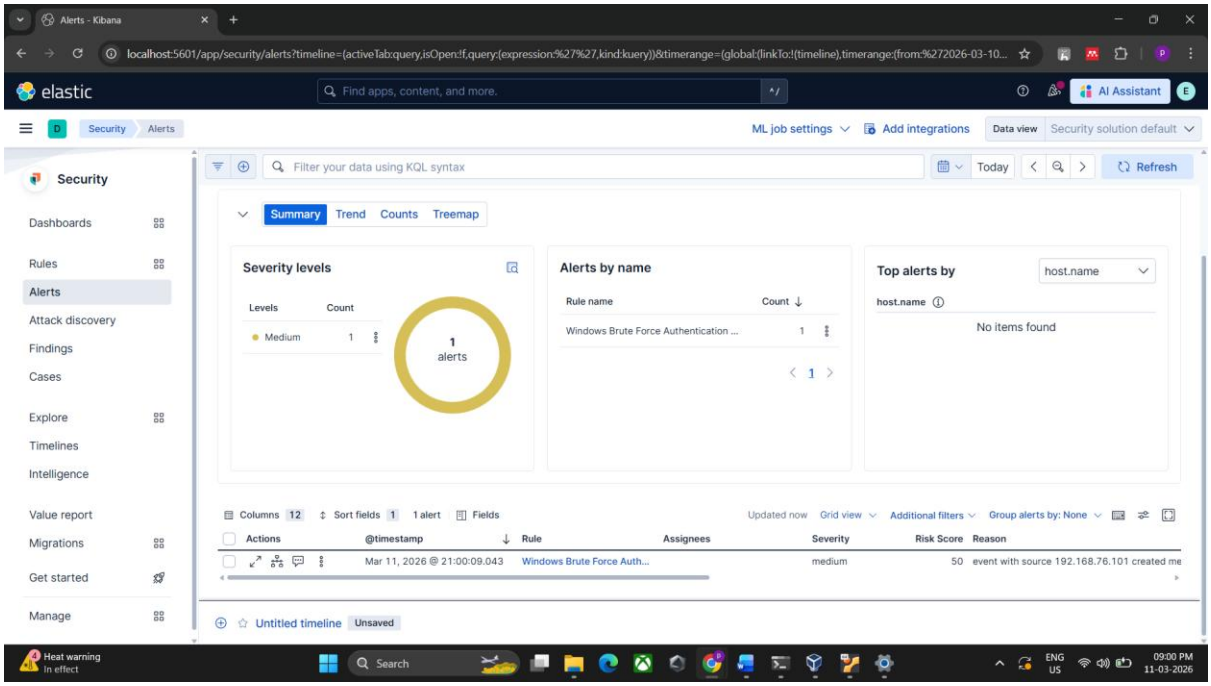

Figure 8 – Elastic SIEM alert triggered by repeated authentication failures

6. Attack Timeline Analysis

6.1 Objective

The purpose of this section is to analyze the sequence of events generated during the brute-force authentication simulation.

By reviewing the collected logs in Elastic SIEM, it is possible to reconstruct the attack timeline and understand how the brute-force activity occurred on the target system.

This process is commonly performed by Security Operations Center (SOC) analysts during incident investigations.

6.2 Timeline of Events

During the attack simulation, multiple authentication attempts were generated from the Kali Linux attacker machine targeting the Windows system.

The following sequence of events was observed:

Date	Time	Event
11 Mar 2026	20:59:04	First authentication attempt from attacker IP
11 Mar 2026	20:59:06	Second failed login attempt
11 Mar 2026	20:59:08	Third failed login attempt
11 Mar 2026	20:59:10	Fourth failed login attempt
11 Mar 2026	20:59:12	Fifth failed login attempt
11 Mar 2026	20:59:14	Additional authentication attempts observed

All authentication failures generated Windows Security Event ID 4625.

6.3 Attack Indicators

The investigation revealed several indicators that are commonly associated with brute-force attacks:

• Multiple failed login attempts in a short time window
• Repeated authentication attempts targeting the same user account
• Authentication requests originating from a single external IP address

Example log fields observed in Elastic:

Field	Value
source.ip	192.168.76.101
user.name	Pratham
event.code	4625
host.name	pratham

These indicators strongly suggest credential brute-force activity.

6.4 Analyst Investigation Process

In a real SOC environment, analysts would perform the following investigation steps:

1. Identify repeated authentication failures

2. Determine the source IP address of the attacker
3. Identify the targeted user account
4. Review the timeline of authentication attempts
5. Check for any successful login events following the failures

This investigation helps determine whether the activity represents malicious behavior or normal user authentication errors.

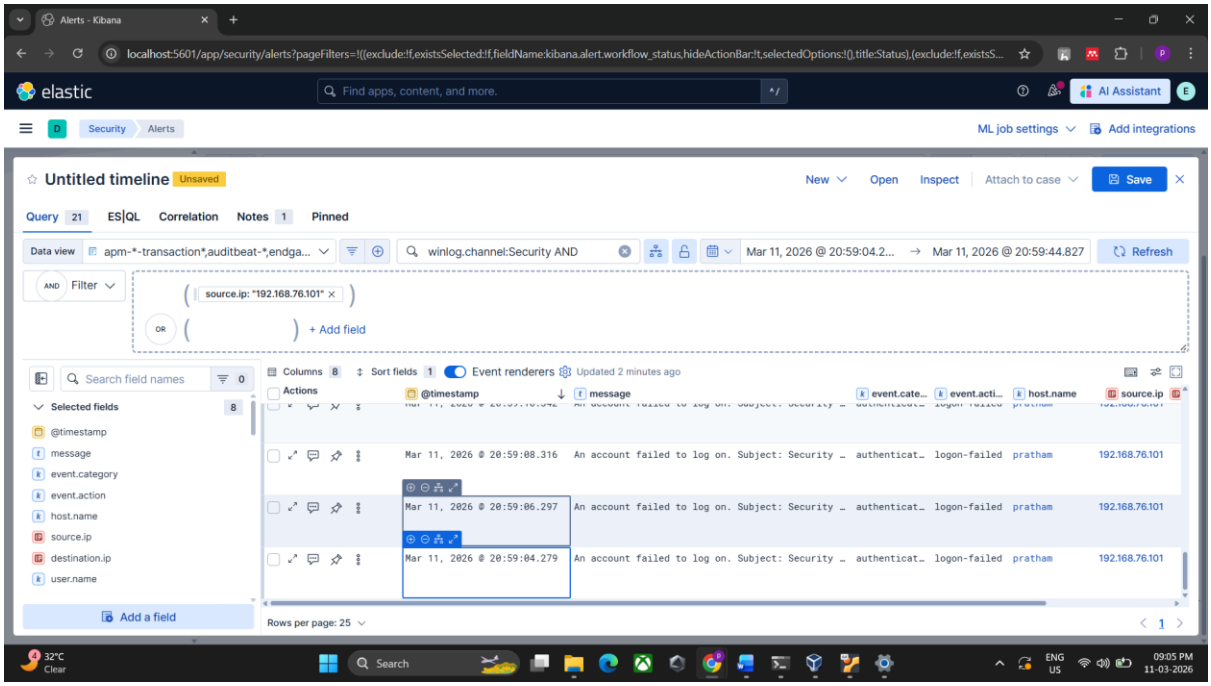

Figure 8 – Timeline of repeated authentication failures

7. Security Analysis and Investigation

7.1 Objective

The objective of this phase is to analyze the authentication failure logs generated during the brute-force attack simulation and determine whether the activity represents malicious behavior.

Security analysts typically perform this type of investigation when an alert is triggered by a detection rule in the SIEM platform.

7.2 Alert Trigger

The detection rule created in the previous section monitored Windows authentication failures using Event ID 4625.

The rule was configured to trigger an alert when multiple failed authentication attempts were detected from the same source IP address within a short time window.

Detection condition:

- More than 5 failed login attempts
- from the same source IP
- within 1 minute

Once the attack simulation was executed, the detection rule triggered an alert in Elastic Security.

7.3 Investigation Process

After the alert was triggered, the investigation process involved reviewing the related authentication events in Elastic SIEM.

The following steps were performed during the investigation:

1. Identify the source IP address responsible for the authentication attempts
2. Review the number of failed login attempts
3. Identify the targeted user account
4. Examine the timeline of authentication attempts
5. Check if any successful login events occurred after the failed attempts

This process helps determine whether the activity is a legitimate user error or a potential brute-force attack.

7.4 Key Findings

The investigation revealed the following indicators:

Field	Value
Source IP Address	192.168.76.101
Target Username	Pratham
Event ID	4625
Hostname	pratham
Attack Type	Brute-force authentication attempt

Analysis of the logs showed multiple authentication failures originating from the same source IP address within a short time window.

This pattern strongly indicates credential brute-force activity.

7.5 Investigation Outcome

Based on the analysis of the authentication logs, the activity was identified as a simulated brute-force attack performed during the lab exercise.

The detection rule successfully identified the attack pattern and generated an alert, demonstrating that the Elastic SIEM detection logic works as expected.

8. False Positive Reduction and Detection Tuning

8.1 Objective

While detecting brute-force authentication attacks is critical, poorly tuned detection rules can generate excessive alerts from normal user behavior. These alerts are referred to as false positives, where legitimate activity is incorrectly classified as malicious.

The objective of this phase is to refine the brute-force detection rule to reduce false positives while maintaining detection accuracy.

Detection tuning ensures that security analysts focus on real attack activity rather than normal authentication errors.

8.2 Common Sources of False Positives

Several legitimate activities can generate multiple authentication failures that resemble brute-force attacks.

Examples include:

Scenario	Description
User is entering an incorrect password repeatedly	Users may mistype their password several times
System services are retrying authentication	Applications may automatically retry authentication
Local authentication attempts	Local system processes may generate authentication logs
Scheduled administrative tasks	Automated tools may attempt login periodically

Without filtering these behaviors, detection rules may produce unnecessary alerts.

8.3 Improved Detection Query

To reduce false positives, additional filters were added to the detection query.

The updated detection query focuses only on external authentication attempts and excludes local system activity.

Detection Query:

- winlog.channel:Security
  AND event.code:4625
  AND source.ip:*
  AND NOT source.ip:127.0.0.1
  AND NOT source.ip:::1
  AND NOT winlog.event_data.TargetUserName:ANONYMOUS*
  AND NOT user.name:"SYSTEM"
  AND NOT user.name:"LOCAL SERVICE"
  AND NOT user.name:"NETWORK SERVICE"

Query Explanation

Filter	Purpose
event.code:4625	Detect failed authentication attempts

source.ip:*	Only include events with a network source
NOT source.ip:127.0.0.1	Exclude local system authentication
NOT user.name:SYSTEM	Exclude system-level authentication attempts
NOT user.name:LOCAL SERVICE	Exclude Windows service authentication
NOT user.name:NETWORK SERVICE	Exclude Windows network service activity

These filters significantly reduce false positives caused by internal system processes.

8.4 Threshold-Based Detection

Instead of triggering alerts for every failed login attempt, the detection rule uses a threshold condition.

Example threshold configuration:

Parameter	Value
Group By	source.ip
Threshold	5 events
Time Window	1 minute

Detection Logic:

- More than 5 failed login attempts
- from the same source IP
- within 1 minute

This approach ensures that only repeated authentication failures trigger alerts, which is more consistent with brute-force attack behavior.

8.5 Advanced Detection Enhancements

To further improve detection accuracy, additional behavioral indicators can be monitored.

Advanced indicators include:

• Multiple usernames targeted from the same IP address
• Authentication attempts across multiple hosts
• High failure rate followed by a successful login event
• Login attempts occurring outside normal working hours

Example advanced detection logic:

- event.code:4625
  AND source.ip:*
  AND NOT source.ip:127.0.0.1

Combined with a threshold rule:

- More than 10 authentication failures
- across multiple user accounts
- within 2 minutes

This pattern strongly indicates automated brute-force activity.

8.6 Detection Tuning Outcome

After applying detection tuning techniques, the brute-force detection rule became significantly more accurate.

Key improvements include:

• Reduced false positive alerts
• Improved detection reliability
• Better visibility into potential credential attacks
• Lower investigation workload for SOC analysts

This tuning process reflects the real-world practices used by Security Operations Centers when maintaining SIEM detection rules.

9. Incident Response and Mitigation

9.1 Objective

After detecting a brute-force authentication attack, the next step for a Security Operations Center (SOC) analyst is to respond to the incident and prevent further unauthorized access attempts.

The purpose of this phase is to mitigate the attack by blocking the attacker's source IP address and implementing defensive controls to prevent similar attacks in the future.

9.2 Immediate Response Actions

Once the detection rule identifies repeated authentication failures from a specific IP address, the following actions should be performed:

1. Identify the attacker IP address from the SIEM alert
2. Verify the number of authentication failures
3. Confirm the targeted user account
4. Determine whether the activity is malicious or legitimate
5. Initiate mitigation measures if malicious activity is confirmed

Example investigation data:

Field	Value
Source IP	192.168.76.101
Target User	Pratham
Event ID	4625
Attack Type	Brute-force authentication attempt

9.3 Blocking the Attacker IP Address

One of the most effective mitigation strategies is to block the attacker IP address using firewall rules.

Block IP using Windows Firewall

On the Windows system, the following command can be executed:

- netsh advfirewall firewall add rule name="Block Brute Force Attacker" dir=in action=block remoteip=192.168.76.101

This rule blocks all incoming connections from the attacker IP address.

9.4 Implement Account Lockout Policy

To prevent brute-force attacks, organizations typically implement an account lockout policy.

Example configuration:

Setting	Value
Account lockout threshold	5 failed login attempts
Lockout duration	15 minutes
Reset counter after	15 minutes

This ensures that an account becomes temporarily locked after several failed authentication attempts.

9.5 Enable Multi-Factor Authentication (MFA)

Another effective mitigation technique is the use of Multi-Factor Authentication (MFA).

MFA requires users to provide additional verification such as:

• One-time passwords
• Mobile authentication applications
• Hardware security tokens

This significantly reduces the effectiveness of brute-force attacks.

9.6 Network Security Improvements

Additional defensive controls can be implemented to prevent similar attacks in the future:

• Restrict SMB access to trusted internal networks
• Implement network segmentation
• Monitor authentication logs continuously
• Deploy intrusion detection systems (IDS)

These measures improve the overall security posture of the environment.

9.7 Incident Response Outcome

After blocking the attacker IP address and implementing security controls, the brute-force attack activity was successfully mitigated.

The detection rule created in Elastic SIEM enabled the SOC team to quickly identify the attack pattern and respond accordingly.

This demonstrates the importance of automated detection combined with rapid incident response in defending against credential-based attacks.

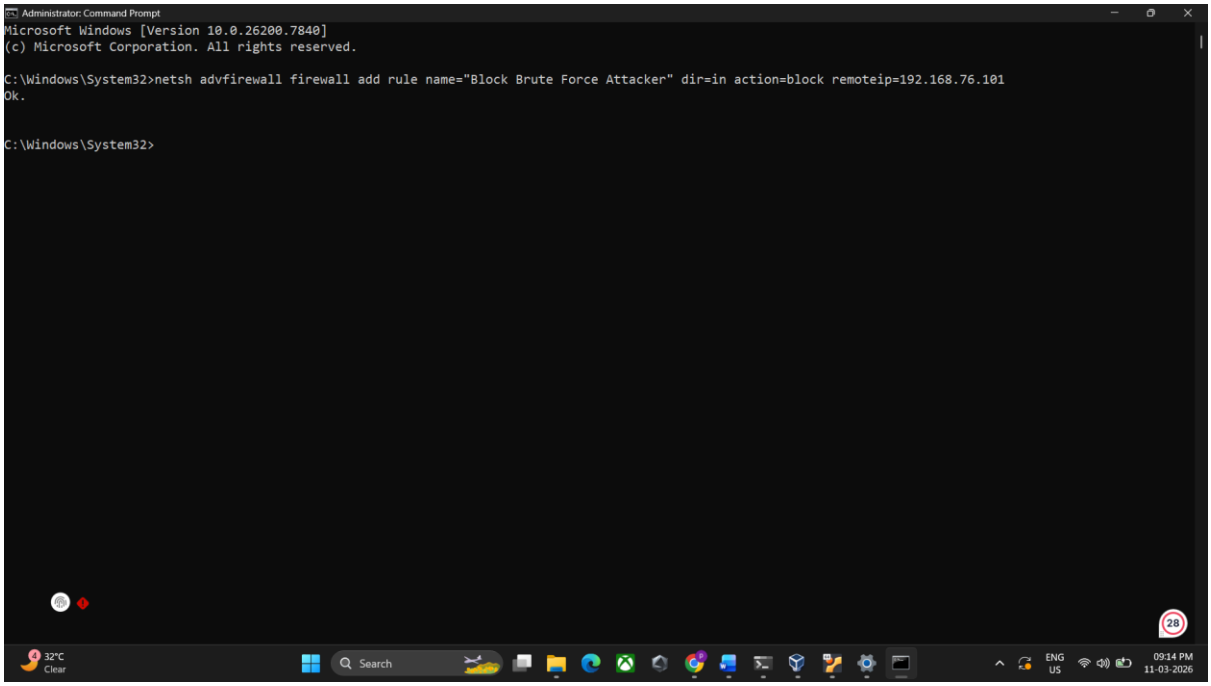

Figure 9 – Firewall rule blocking attacker IP address

10. Conclusion

This project demonstrated the practical implementation of a Security Operations Center (SOC) detection workflow using Elastic SIEM to identify and analyze brute-force authentication attacks against a Windows system.

A controlled lab environment was created consisting of a Kali Linux attacker machine and a Windows 11 target system. The Windows system was configured to generate security logs, which were collected using Winlogbeat and forwarded to the Elastic SIEM platform for monitoring and analysis.

During the attack simulation phase, repeated authentication attempts were performed against the Windows SMB service using incorrect credentials. These attempts generated multiple Windows Security Event ID 4625 logs, representing failed login attempts.

The generated logs were analyzed in Elastic SIEM to identify patterns associated with brute-force attacks. A detection rule was then developed to automatically identify suspicious authentication behavior by detecting multiple failed login attempts originating from the same source IP address within a short time window.

The detection rule was aligned with the MITRE ATT&CK framework, specifically the Brute Force technique (T1110 – Credential Access), which is commonly used by adversaries attempting to compromise user credentials.

Additional improvements were implemented to reduce false positives and improve detection accuracy. Detection tuning techniques such as filtering system accounts and excluding local authentication attempts were applied to ensure that alerts focus on potentially malicious activity.

Once the attack was detected, incident response procedures were outlined to demonstrate how a SOC team would investigate the alert, identify the attacker IP address, and apply mitigation strategies such as blocking the malicious IP address and implementing stronger authentication controls.

Overall, this project highlights the importance of log monitoring, detection engineering, and incident response in defending against credential-based attacks. It demonstrates how SIEM platforms can be used to detect suspicious authentication behavior and enable security teams to respond quickly to potential threats.

This hands-on exercise provides valuable insight into the workflow used by real-world Security Operations Centers to detect and respond to brute-force authentication attacks.